

Obligatory Exercise 3

- I. Choosing 4 and 7 as threat thresholds are the obviously bad choices because in the example, 7 is handled, and it is handled to a 4. This means that 4 is likely an acceptable risk level that we choose not to handle whilst 7 must be (and I agree). Instead of a 5 I decided to go with a 6 as the threat threshold (meaning that 6 or above is to be acted upon) level because I don't think that something with a threat level of 4 should be happening, nor any situation where threat level of 2, 3, or even higher become frequent, nor when everyone abuses a threat level of 1.
- II. Since the university has campuses in multiple cities, I assume it has like 20,000 students. I assume that 1% of students are willing to cheat as well. Based on this and the fact that exams are being held each semester (2 a year) I believe that $S = 400$ (e.g. 400 cases a year if frequency risk is at 5) fits well. As for price V I think that I will just multiply it by 8 since that is by how much S has increased. I don't know how much this stuff costs, so $V = 80_000_000$ it becomes.
- III. Here are the tables. This one below is from row 2 to row 7 and columns A to Y.

Nr.	Trussel	Sårbarheter	Berørte verdier	Konsekvenser	Eksisterende sns-reducerende tiltak	Eksisterende kv-reducerende tiltak	Evne til deteksjon av event eller hendelse	Begrunnelse for sannsynlighet	Begrunnelse for konsekvens
Beskrivelse	Hvordan foregår angrepet? Hvem eller hva kan stå bak? Hvilke trinn inngår i scenarioet? Hvem eller hva trigger hendelsen? For tilskittede hendelser: Hvilken kapasitet og motiv har trusselaktøren?	Hvordan utnyttes svakheter og sårbarheter? Hva gjør at trusselscenariotet er gjennomførbart og at angrepet kan bli vellykket sett fra trusselaktørens perspektiv?	Hvilke verdier er berørt? Hvilke sikkerhetsbrudd oppstår? Er det brudd på ett eller flere av sikkerhetsmålene KIT + P for en eller flere verdier?	Mulige negative konsekvenser? Typiske negative konsekvenser er: tappt fortjeneste, utfall/svekkelse av tjenester, juridiske konsekvenser, tappt omdømme, kostnad ved gjenoppretting.	Hva gjør hendelsen mindre sannsynlig? Hvilke eksisterende tiltak har vi som kan stoppe eller bremse trusselen slik at sannsynligheten for hendelsen reduseres?	Hva gjør konsekvensene mindre alvorlig? Hvilke eksisterende tiltak har vi som kan redusere hendelsens konsekvensene hvis hendelsen inntreffer?	Hvordan kan vi oppdage denne type hendelse? Hvilke metoder eller måter har vi som gjør at vi kan oppdage relevante eventer eller selve hendelsen?	Hvilke relevante momenter påvirker sannsynligheten? Hvordan vurderes momentene i sammenheng, og hva blir estimert sannsynlighet?	Hvilke konsekvensaspekter er relevante? Hva er estimert størrelse på hvert konsekvensaspekt, og på helhetlig konsekvens?
Eksempel	Prosjektmedarbeidere kan kopiere inn data fra prosjektet til sine usikrede håndholdte enheter. Disse kan igjen bli angrepet gjennom skadelige apper som overfører data til trusselaktører.	Dårlige holdninger til sikkerhet og uklare policyer. Data kopieres ut til usikrede enheter av bekvemmelighetshensyn.	Forskningsresultater eller annen sensitiv informasjon kommer uvedkommende i hende, som betyr brudd på konfidensialitet.	Tap av konfidensialitet kan medføre konsekvens i form av økonomiske tap, tap av tillit eller gjennomføringsvegne osv.	Intet spesifikt kan forhindre hendelsen, men det det vil likevel kreve et relativt målrettet angrep fra en trusselaktør.	Intet spesifikt kan redusere konsekvensene hvis hendelsen inntreffer.	Aktiv gjennomgang av Netflowdata kunne påvise overføring til usikre enheter, men gjøres ikke. Deteksjon av dataauthenting gjennom apper ville være krevende, og gjøres ikke.	Pga. dårlige holdninger til sikkerhet og mangel på tekniske tiltak som kan oppdage eller forhindre hendelsen regnes sannsynligheten som høy (4).	Forskningsdata som kan bli stjålet er ikke personsensitive, men kan ha betydelig kommersiell verdi. I tillegg vil det påvirke partners tillit til virksomheten negativt. Derfor regnes konsekvensen som betydelig (3).

Kvalitativt risikonivå			Kvantitativt risikonivå			Anbefalte nye sikkerhetstiltak		Begrunnelse for sannsynlighet og konsekvens etter nye tiltak		Kvalitativt risikonivå etter		Kvantitativt risikonivå etter håndtering			Risikoreduksjon
Kvalitativt risiko på skala 0 - 10 er summen av sannsynlige P og konsekvens K på			S		V	Beskriv forslag til nye tiltak for å redusere sannynlighet og/eller konsekvens, og for oppdaging av hendelser.		Hvordan endres estimering av sannsynlighet og konsekvens som følge av nye tiltak? Hva blir nye nivåer for estimert sannsynlighet og estimert konsekvens av hendelsen.		Kvalitativt risiko på skala 0 - 10 er summen av sannsynlige P og konsekvens K på kvalitativt skala 0 - 5		Risiko er produkt av sannsynlighet og konsekvens. N og M er kalibreringsfaktorer for sannsyn. og konsekv.			R(reduksjon)
P	K	R(før)	P	K	R(før)							P	K	R(etter)	
4	3	7.0	20.0	8.00E+05	1.60E+07	Organisatoriske: Opprette klare policyer og rutiner for sikker lagring av konfidensiell informasjon i virksomhetens nettverk. Menneskelige: Opplæring og bevisstgjøring. Teknologiske: Deteksjon av dataauthenting gjennom Netflow.	Gjennom organisatoriske og tekniske tiltak blir sannsynligheten betydelig redusert, og estimeres til å være lav (1). Potensiell konsekvens er ikke påvirket, og forblir derfor betydelig (3).	1	3	4.0	0.0	8.00E+05	1.60E+04		1.5984E+07

The rest are rows 8, 9, and 10 coming in pairs (columns A to J, then K to Y)

A	Students can get exam questions before the exam start. Those students may want to resell those exam questions or desperate/extreme students want better grades (because all of their future opportunities are at stake). Those exam papers can be purchased from the hacker on dark web.			Weak/Vulnerable authentication system, leaked professor or admin authentication credentials, professor working on a new exam from an infected device (spyware), insider job, forgot to log out.			The exam tasks are accessed by unauthorized entities. These can be revealed prematurely to students which are going to take that same exam. This is a breach of confidentiality.			Some students get an unfair advantage, create cheat sheets, or memorize answers before the exam starts. This reduces university's public view, diploma credibility, prestige, and financial aid (especially if private).			When creating an exam make sure it is accessed from a safe device like a work computer (personal ones might have a spyware and such). Make sure that no-one unauthorized gets to see what you work on. Make sure that the device is up to date and that you log out once finished.			Create new passwords, check device for spyware, inform personnel of the incident to raise awareness, assign the task to someone else who can handle it, and only then, create new exam tasks or modify current ones. Fix this problem asap so that the rest of the exams don't follow the same fate. Might as well try to catch the students with various methods. I won't go into that but I do have a lot of great ideas. For example, publish the fake answers to that exam too (as if leaked).			Search for it in the dark web ourselves. Be aware of the rumours (knowledge about this type of stuff usually spreads). Check the access logs (if there are any). The Netflowdata app that I definitely knew about before.			It can be easily done by the hacker, all you have to do is to get in touch through the dark web. Note that not everyone is going to be doing that though. But some that do might resell those exams to other students later.			Many students will likely pass, and some might get caught which would bring consequences to them and the university. Universities get paid for having good students (I think) and research that is done, so profits as well as some reputation is lost. This will also cause some problems with NOKUT.		
	5	3	8.0	200.0	8.00E+05	1.60E+08	If there isn't one, have a double-authentication in place (with a one time code from your phone which you always carry with you). There might be a spyware so simply wipe the pc (backup all important data carefully). After that, consider changing your password. Logs are a preferable option to see if any exploits were used (in case hacker got it through different means). Make sure to train personnel such that phishing or social engineering won't be used (because it could have been). If logs revealed an unauthorized access then contact Expera to report an authentication exploit being used and switch to a more secure one.			The training and counter measures are likely to get rid of the vulnerability. It does not get rid of the possibility of there being a smart insider or a strong exploit, so the probability is estimated to be a (2). Unfortunately, I don't think there is much we can do about the exam so the consequence stays a (3).			2	3	5.0	0.2	8.00E+05	1.60E+05	1.60E+08								
B	Students can alter their exam grades without authorized access. Desperate/Extreme students want better grades (because all of their future opportunities are at stake). Those exam grades can be tempered with by a hacker on dark web whose services can be purchased.			Similar to A. Weak/Vulnerable authentication system, examiner or admin leaked authentication credentials (could also be from spyware), insider job.			The exam grades are accessed by unauthorized entities and tempered with. This is a breach of integrity.			Similar to A. This directly reduces university's public view, diploma credibility, prestige, and financial aid massively due to NOKUT's rules that must be followed.			Make sure that only authorized examiners are allowed to grade the student's work.			Re-evaluate from scratch. If there were logs that show unauthorized access then you might figure out what it was supposed to be. Hopefully there are backups for that kind of stuff, idk.			Similar to A. Search for it in the dark web ourselves. Be aware of the rumours (knowledge about this type of stuff usually spreads). Check the access logs (if there are any).			It can be easily done by the hacker, all you have to do is to get in touch through the dark web. Note that not everyone is going to be doing that though. But some that do might tell others about it.			Many students will likely pass and older grades from other exams are also at risk. This will cause huge problems with NOKUT, bigger since all the exam grades of all the students are at risk here, but not their accounts.		
	Students that want to postpone or cancel the exam might get in contact with the hacker on dark web and request a DDOS attack before exam start or during exam (to force rework of exam questions or get more time to think).			Since It is Expera that is handling all the traffic they can have a bad firewall filtering system / architecture. But DDOS is hard to defend against to be honest.			Accessability is at stake here because that is what DDOS does, it is in the name (Distributed Denial of Service).			Exams will have to be rescheduled or maybe even canceled (I don't think so though), new exam questions might have to be made or more time given to students (or manually check if they are still editing at the end of time, even though not allowed).			There isn't really much that can be done. This is literally all the traffic that you can handle right now.			There isn't really much that can be done. This is literally all the traffic that you can handle right now.			I don't think that this is something that could be suspected in this situation unless it has happened recently before or a dark web page of it was found (and you think it was used).			Well, in our scenario it can be easily done by finding the dude from dark web which is also considered more harmless and thus might be more "ok", but less desirable as well. However, it may not have any effect if the system is set up properly.			This is an inconvenience at most which only becomes a problem if it isn't solved for an extended period of time.		
C	5	4	9.0	200.0	8.00E+06	1.60E+09	If there isn't one, have a double-authentication in place (with a one time code from your phone which you always carry with you). There might be a spyware so simply wipe the pc (backup all important data carefully). After that, consider changing your password. Logs are a preferable option to see if any exploits were used (in case hacker got it through different means). Make sure to train personnel such that phishing or social engineering won't be used (because it could have been). If logs revealed an unauthorized access then contact Expera to report an authentication exploit being used and switch to a more secure one. Lastly, try to get in touch as one of the students with the hacker and maybe get some information about him, something as simple as a bank account should be sufficient to find out whether there is an insider among us (although not guaranteed). Oh, and lets hope we got backups, though who knows when all of this took place. Eventually consider switching to a different platform other than Expera, we can figure out if it is the problem if the hacker is able to alter exam grades or get exams from all the universities that implement Expera.			The training and counter measures are likely to get rid of the vulnerability (1). Unfortunately, I don't think there is much we can do about the exam grades so the consequence stays a (4).			1	4	5.0	0.0	8.00E+06	1.60E+05	1.60E+09								
	3	2	5.0	2.0	8.00E+04	1.60E+05	Since this is an option listed by a malicious actor, it is worth looking into and perform a check on how well the load is being handled. Since it is Expera handling all this we might consider switching to a different provider or contact Expera about this. Having an alternative option would be nice as well as implementing DDOS mitigation tools if they haven't been yet.			After this only the biggest DDOS attack networks could take the accessability down which is very unlikely to happen at this scale (if ever), so the frequency goes to (1). As for severity, it is questionable since it depends on persistency ranging anywhere from 1 to 3, so a (2) it stays.			1	2	3.0	0.0	8.00E+04	1.60E+03	1.58E+05								

IV. Here is a picture of before and after action taken (risk evaluation)

Mulighet \ Skade	Ingen (0)	Ubetydelig (1)	Liten (2)	Betydelig (3)	Stor (4)	Verst (5)
Snarest (5)	5	6	7	8	9	10
Sannsynlig (4)	4	5	6	7	8	9
Mulig (3)	3	4	5	6	7	8
Usannsynlig (2)	2	3	4	5	6	7
Sjeldent (1)	1	2	3	4	5	6
Aldri (0)	0	1	2	3	4	5

Basically, the hacker on dark web could be a problem worth investigating. He could have access to the database through someone's account like admins and therefore had access to exams and student grades this way. If he does, it is wise to get a fresh wipe on pcs that are being used to authorize to eliminate chances of having spyware and get a two-factor authentication to make it harder next time. Then, update those passwords to cut the hacker off. Stronger measures could be required if this fails.